

TAREA IC04

Plan de respuesta ante Incidentes.

Autor: Carlos España Del Pozo - CETI

Contenido

Los Procedimientos de Actuación ante Incidentes.....	4
Apartado 1: Manifestación y detección del incidente.	5
Apartado 2: Definir los roles de las personas y formación del equipo de respuesta.....	5
Apartado 3: Concreción del incidente.	5
Apartado 4: Medidas de actuación ante diferentes tipos de incidentes.....	6
Apartado 5: Proceso de revisión, documentación y mejora.	6
Plan de respuesta a incidentes para <i>Empresa Ficticia</i>	7
1. Introducción.....	7
2. Evaluar.....	7
2.1. Evaluar el impacto funcional.....	8
2.2. Evaluar el impacto de la información.....	8
3. Iniciar la respuesta.....	8
3.1. Nombre del incidente.....	8
3.2. Reunir el equipo de respuesta.....	8
3.3. Composición del Equipo de Respuesta a Incidentes.....	9
4. Roles y responsabilidades.....	9
5. Investigación y análisis de evidencias.....	10
5.1. Supervisión del Alcance.....	10
5.2. Sub-Equipos de Investigación.....	10
5.3. Gestión de Incidentes Múltiples.....	11
5.4. Creación y Gestión del Archivo del Incidente.....	11
5.5. Recogida de Pistas Iniciales.....	12
5.6. Recursos de Respuesta.....	12
6. Remediación.....	12
6.1 Contención.....	12
6.2 Erradicación.....	13
6.3. Recuperación.....	13
6.4. Coordinación con Investigación y Comunicación.....	13
7. Playbook de Respuesta a incidentes.....	14
7.1. Playbook: Infección por Gusanos.....	14
7.2. Playbook: Ataque de Phishing.....	15
7.3. Playbook: Malware en Sistemas Windows.....	16
7.4. Playbook: Ataque de Denegación de Servicio (DDOS).....	17

7.5. Playbook: Ransomware.....	18
8. Cierre del incidente y Revisión Posterior (AAR).....	18
8.1. Convocatoria y Preparación del AAR.....	18
8.2. Desarrollo de la Reunión de AAR.....	18
8.3. Comunicación y Estado del AAR.....	19
9.4. Incorporación de Lecciones Aprendidas.....	19

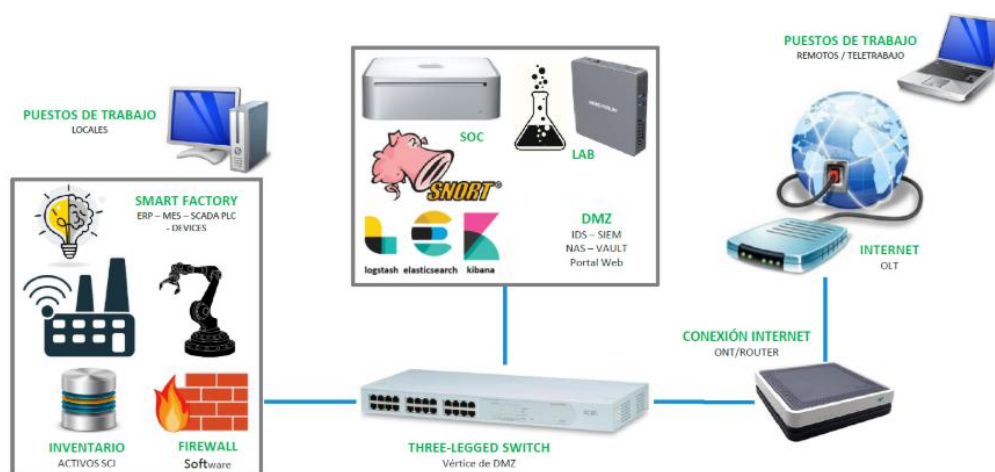
Los Procedimientos de Actuación ante Incidentes.

Como hemos estudiado en la Unidad 4, en los momentos iniciales de manifestación de un incidente suele existir un cierto desconcierto en lo relativo a las medidas que se deben tomar, por parte de quién y en qué orden, lo cual suele aumentar la afectación del incidente.

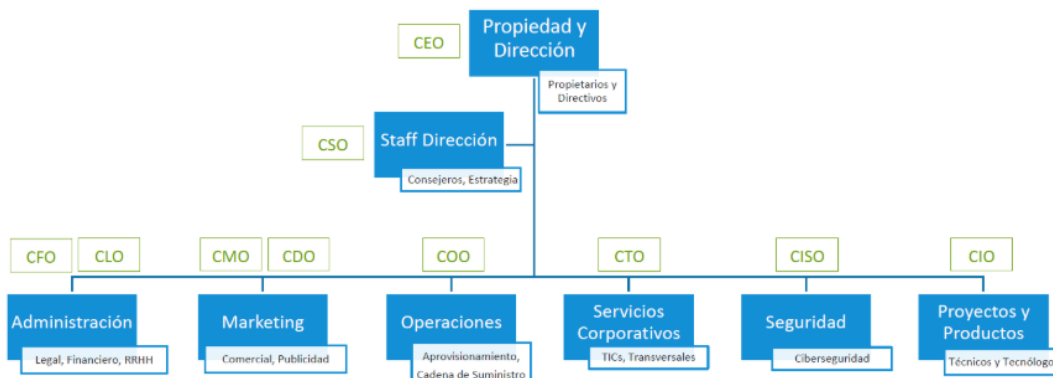
Este desconcierto se combate diseñando un Procedimiento de Actuación ante Incidentes. Este procedimiento suele ser de alto nivel y podrá desglosarse en tareas concretas en función del área involucrada en cada caso, o bien, en flujos de decisión y escalado para constituir la Estrategia de Contención de Incidentes de Ciberseguridad.

Introducción: Estructura de la Organización Empresarial.

Dada una empresa como la descrita en la tarea de la unidad de trabajo 1 en la que se sigue el siguiente diagrama de bloques:



Además, esta empresa sigue la siguiente estructura organizativa:



- La determinación de la Estructura de la Empresa Ficticia nos permitirá identificar sus áreas de trabajo y las misiones de las mismas , con objeto de saber a qué equipos hay que involucrar en cada momento y cuándo se les debe informar acerca de los incidentes:
 - CEO (Chief Executive Officer): Presidente. Gestión y Dirección administrativa.
 - COO (Chief Operating Officer): Director de Operaciones.

- CFO (Chief Financial Officer): Director de Gestión Financiera.
- CMO (Chief Marketing Officer): Director de Actividades Comerciales y de Marketing.
- CIO (Chief Information Officer): Director de Sistemas de Información y Desarrollo de Aplicaciones.
- CTO (Chief Technology Officer): Director de Tecnología y Estrategia Tecnológica.
- CSO (Chief Security Officer): Responsable de Planificación y Estrategia de Seguridad.
- CISO (Chief Information Security Officer): Responsable de Ciberseguridad.
- CLO (Chief Legal Officer): Responsable del Departamento Jurídico. Es clave para la ciberseguridad.
- CDO (Chief Design Officer): Responsable de Diseño.

Con esta información proporcionada se tiene una idea general de la estructura de la empresa. El grupo de trabajadores de cada departamento y la inclusión de otros posibles departamentos queda a libre elección del alumno.

A continuación, se desglosan en apartados el desarrollo general de un Plan de Actuación ante Incidentes de Ciberseguridad. En este Plan de Actuación no se solicitan detalles a bajo nivel de herramientas a usar, solamente una **guía de actuación general**.

Apartado 1: Manifestación y detección del incidente.

Deberás efectuar la siguiente tarea:

- Describir procesos para identificación, recopilación de evidencias y evaluación inicial de incidentes.

Apartado 2: Definir los roles de las personas y formación del equipo de respuesta.

Deberás efectuar la siguiente tarea:

- Definir que funciones tendrá asignadas cada rol definido en caso de un incidente. Llamada a filas del equipo en caso de incidente.
- Indicar los miembros de alta prioridad a los que se les trasladará información preliminar

Apartado 3: Concreción del incidente.

Deberás efectuar la siguiente tarea:

- Indicar principales pasos o preguntas a realizar para detectar de forma más concreta el tipo de incidente que puede estar sucediendo.
- Personal de empresa a los que informar.

Apartado 4: Medidas de actuación ante diferentes tipos de incidentes.

Deberás efectuar la siguiente tarea:

- a. Descripción general de las fases de contención, mitigación, o eliminación de los incidentes.
- b. Describir de forma concreta estas fases para un tipo específico de incidente (Playbook). Los tipos a elegir son: infección por gusanos, phishing, malware en Windows, DDOS y ransomware.

Apartado 5: Proceso de revisión, documentación y mejora.

Deberás efectuar la siguiente tarea:

- Definir el proceso de cierre de la incidencia, la documentación asociada, el aprendizaje adquirido y proceso de mejora.
- Traslado de información a las personas o entidades necesarias.

Plan de respuesta a incidentes para *Empresa Ficticia*

Autor: Carlos España, cespana@gmail.com

Revisión 1.0, Publicado 1.0

Este plan de respuesta a incidentes está basado en el plan conciso, directivo, específico, flexible y gratuito disponible en [Github](https://github.com/counteractive/incident-response-plan-template) de Counteractive Security y discutido en [www.counteractive.net](https://www.counteractive.net/posts/an-ir-plan-you-will-use/)

Fue revisado por última vez el 25/01/2026, Fue probado por última vez en 25/01/2026.

1. Introducción

El presente Plan de Respuesta ante Incidentes de Ciberseguridad establece las directrices generales que debe seguir la empresa ficticia ante la detección, análisis, gestión y resolución de incidentes relacionados con la seguridad de la información.

La empresa cuenta con una estructura organizativa jerárquica en la que destacan los siguientes roles: CEO, COO, CFO, CMO, CIO, CTO, CSO, CISO, CLO y CDO. Esta estructura permite una gestión coordinada de incidentes, garantizando la correcta toma de decisiones técnicas, legales, económicas y comunicativas.

2. Evaluar

- Ante la detección de cualquier evento anómalo o sospechoso relacionado con la seguridad de la información, la primera acción será mantener la calma y actuar con profesionalidad. El objetivo de esta fase es determinar si el evento constituye un incidente de ciberseguridad que requiera la activación formal del Plan de Actuación.
- En primer lugar, la persona que detecta el evento deberá reunir la información disponible (observación), incluyendo alarmas del sistema, eventos registrados, comportamientos anómalos, datos relevantes y, en su caso, suposiciones razonables basadas en la experiencia o intuición profesional.
- A continuación, esta información será analizada para orientar la evaluación, considerando el posible impacto funcional y el impacto sobre la información. Con base en este análisis, se tomará la decisión de clasificar el evento como incidente o no incidente. En caso de duda, se aplicará el principio de precaución y se iniciará la respuesta de forma preventiva. Posteriormente, el responsable del Incidente (CISO) y el Equipo de Respuesta podrán ajustar la clasificación tras una investigación más detallada.

2.1. Evaluar el impacto funcional

Se analizará el impacto directo o potencial sobre la misión de la empresa, incluyendo la continuidad del negocio, la productividad de los empleados, la prestación de servicios y la confianza de clientes y proveedores.

Se considerará incidente cualquier situación que provoque degradación significativa del servicio, interrupción de operaciones o imposibilidad de cumplir los objetivos empresariales.

2.2. Evaluar el impacto de la información

Se evaluará si la información corporativa ha sido accedida, modificada, eliminada, cifrada o exfiltrada sin autorización. Se prestará especial atención a datos sensibles, como información personal, financiera, estratégica o protegida por normativa legal.

Cualquier acceso no autorizado o alteración de este tipo de información será clasificado como incidente de ciberseguridad.

En caso de que no exista impacto sobre la información ni sobre la misión de la empresa, el evento podrá gestionarse a través de canales ordinarios no relacionados con incidentes, como el soporte técnico.

3. Iniciar la respuesta

Cuando se confirma la existencia de un incidente, se iniciará formalmente la respuesta. El CISO asumirá el rol de responsable de Incidente y será responsable de coordinar todas las acciones.

3.1. Nombre del incidente

Con el objetivo de facilitar la comunicación interna, el seguimiento del incidente y la documentación asociada, cada incidente recibirá un **nombre en clave** compuesto por una frase simple de dos palabras. Este nombre se utilizará de forma consistente en todos los registros, comunicaciones internas y archivos relacionados con el incidente.

El procedimiento de nomenclatura se basará en términos neutros que no revelen información sensible sobre el alcance, impacto o naturaleza del incidente, evitando generar alarmismo innecesario o filtraciones de información.

Ejemplo: *puede ser un nombre aleatorio nombre_adjetivo*

3.2. Reunir el equipo de respuesta

El Equipo de Respuesta a Incidentes (ERI) estará formado por representantes de las áreas clave de la organización, incluyendo seguridad, sistemas, legal, operaciones y dirección.

La comunicación del incidente se realizará exclusivamente a través de canales seguros previamente definidos, priorizando la comunicación por voz, mensajería interna segura y el

intercambio protegido de documentación. Se evitará, siempre que sea posible, el uso del correo electrónico corporativo habitual. En caso de que el correo electrónico sea necesario, se utilizarán canales alternativos autorizados y se extremarán las medidas de confidencialidad, especialmente cuando participen personas externas a la organización.

No se utilizarán mensajes SMS ni sistemas de mensajería no autorizados para la gestión del incidente, salvo para indicar a un miembro del equipo que se incorpore a un canal de comunicación más seguro.

3.3. Composición del Equipo de Respuesta a Incidentes

El **ERI** estará formado, como mínimo, por los siguientes perfiles:

- El **CISO** (Chief Information Security Officer), como responsable de Incidente.
- Miembros del **equipo de seguridad** y sistemas de información.
- Personal técnico especializado de los sistemas o servicios afectados.
- Representantes del área legal, liderados por el **CLO**, en caso de posibles implicaciones normativas o legales.
- Representantes de la dirección ejecutiva cuando el impacto lo requiera, priorizando siempre la intervención de los responsables operativos.

La incorporación de los miembros al equipo se realizará de forma progresiva, en función de la gravedad y evolución del incidente, garantizando en todo momento la confidencialidad de la información compartida.

Espacios de coordinación

Para incidentes complejos o de alta gravedad, el responsable de Incidentes podrá establecer un **espacio de coordinación específico**, físico o virtual, destinado a centralizar la toma de decisiones, el intercambio de información y el seguimiento del incidente hasta su resolución.

4. Roles y responsabilidades

CEO: Supervisión general y toma de decisiones estratégicas.

COO: Garantizar la continuidad operativa del negocio.

CFO: Evaluar el impacto económico del incidente.

CMO: Gestionar la comunicación externa y reputacional.

CIO: Gestión de sistemas de información y aplicaciones.

CTO: Apoyo tecnológico y arquitectónico.

CSO: Estrategia global de seguridad.

CISO: Coordinación técnica de la respuesta al incidente.

CLO: Asesoramiento legal y cumplimiento normativo.

CDO: Impacto en diseño y experiencia de usuario, si procede.



5. Investigación y análisis de evidencias

Durante esta fase se recopilarán y analizarán las evidencias necesarias para comprender el alcance del incidente. Esto incluye registros de sistemas, logs de red, evidencias forenses y testimonios.

La preservación de la cadena de custodia será prioritaria para garantizar la validez de las pruebas, especialmente en caso de acciones legales.

5.1. Supervisión del Alcance

- El responsable del Incidente (**CISO**) supervisa todas las acciones de investigación para asegurarse de que se mantengan dentro del ámbito de control establecido.
- En incidentes complejos, se podrán crear subequipos para optimizar la investigación y la respuesta

5.2. Sub-Equipos de Investigación

Se podrán definir tres subequipos principales, cada uno liderado por un responsable que reporta al CISO:

- Investigación: encargado de identificar y analizar evidencias, determinar la magnitud del incidente y detectar el vector de ataque.
- Remediación: responsable de contener, mitigar y erradicar la amenaza (ver apartado 6).

- Comunicación: gestiona la información hacia los equipos internos, la dirección y terceros externos según corresponda.

Reglas de operación:

- Cada subequipo dispone de canales dedicados de comunicación (puente de llamadas y chat).
- Los miembros reportan a su líder, quien a su vez reporta al CISO.
- Los cambios de equipo se podrán gestionar únicamente a través del líder del subequipo actual, respetando la cadena de mando.

5.3. Gestión de Incidentes Múltiples

Si un incidente se divide en dos o más eventos distintos:

- Se debe crear un archivo de incidentes independiente para cada uno.
- Cada archivo contendrá la documentación y evidencias correspondientes, manteniendo seguimiento de investigación, remediación y comunicación.
- Se mantendrá un responsable de Incidente de alto nivel para coordinar recursos compartidos y garantizar coherencia en la respuesta.

5.4. Creación y Gestión del Archivo del Incidente

El **archivo de incidentes** centraliza toda la documentación y evidencias:

- Almacenamiento seguro digital y físico.
- Compartición controlada con subequipos y CISO.
- Contenido mínimo recomendado:
 - Impacto funcional y de la información.
 - Vector del incidente (correo electrónico, web, medios extraíbles, etc.).
 - Resumen ejecutivo del incidente, incluyendo investigación y estado de remediación.
 - Línea de tiempo del incidente: actividad del atacante y del equipo de respuesta.
 - Evidencias detalladas:
 - Pruebas con hora, fuente y cadena de custodia.
 - Sistemas afectados y estado.
 - Archivos de interés (malware, datos, documentos críticos).
 - Datos accedidos o exfiltrados.
 - Actividad significativa de atacantes (logs, accesos, ejecución de malware).
 - Indicadores de compromiso (IoC) de red y host.
 - Cuentas comprometidas: alcance y tiempo de compromiso.

5.5. Recogida de Pistas Iniciales

- Entrevistar a informadores y testigos del incidente.
- Recoger datos de soporte iniciales: alarmas, eventos, informes, suposiciones y observaciones.
- Entrevistar al equipo técnico para comprender detalles técnicos y riesgos asociados.
- Entrevistar a las unidades de negocio afectadas para evaluar impacto en operaciones.
- Validar que todas las pistas sean relevantes, detalladas y procesables.

5.6. Recursos de Respuesta

Recurso	Ubicación
Lista de información crítica	documentación
Lista de activos críticos	documentación y BBDD
Base de datos de gestión de activos	CMDB
Mapa de Red	Documentos Infraestructura
Consola SIEM	SIEM

6. Remediación

Las acciones de remediación tienen como objetivo contener, mitigar y erradicar el incidente. Estas acciones se ejecutarán en paralelo siempre que sea posible, coordinadas por el **responsable del Incidente**.

6.1 Contención

La contención busca limitar el impacto del incidente y prevenir su propagación. Las acciones principales incluyen:

- Aislamiento de sistemas afectados: desconectar equipos o segmentos de la red comprometidos.
- Bloqueo de accesos comprometidos: suspender cuentas, revocar credenciales y deshabilitar accesos no autorizados.
- Segmentación de redes: aplicar controles de red que limiten la comunicación entre sistemas afectados y no afectados, evitando movimiento lateral del atacante.

6.2 Erradicación

La erradicación consiste en eliminar los elementos que causan el incidente y corregir las vulnerabilidades que permitieron el ataque:

- Eliminación de malware: limpieza de archivos maliciosos y procesos asociados.
- Cierre de vulnerabilidades: parcheo de software, actualización de configuraciones y eliminación de puntos débiles.
- Restauración de configuraciones seguras: revertir cambios no autorizados y aplicar políticas de seguridad reforzadas.

6.3. Recuperación

La recuperación asegura que los sistemas y servicios vuelvan a operar de manera segura y confiable:

- Restauración desde copias de seguridad verificadas: recuperación de información y sistemas desde backups confiables.
- Validación de la integridad de los sistemas: revisión de logs, comprobación de la ausencia de malware y verificación de la consistencia de datos y servicios.
- Reintegración controlada de sistemas: reintegrar equipos y servicios al entorno de producción de manera gradual, monitorizando cualquier indicio de reaparición del incidente.

6.4. Coordinación con Investigación y Comunicación

- La fase de remediación debe ejecutarse en paralelo con la investigación (para ajustar acciones según hallazgos) y la comunicación (para mantener informados a los interesados).
- Los líderes de subequipos reportan al CISO, quien mantiene la visión completa del incidente y ajusta prioridades y recursos según evolución.
- La comunicación durante un incidente debe ser controlada y coherente. Toda comunicación externa deberá ser aprobada por el CEO y el CLO.
- Se informará a empleados, clientes, proveedores y autoridades cuando sea legalmente obligatorio.

7. Playbook de Respuesta a incidentes

Este apartado describe de forma concreta las fases de contención, mitigación y erradicación para distintos tipos de incidentes de ciberseguridad. Los playbooks desarrollados se basan en el Plan General de Respuesta ante Incidentes de la empresa ficticia y permiten una actuación ordenada, eficaz y coordinada.

7.1. Playbook: Infección por Gusanos

Detección: La infección por gusanos suele detectarse mediante un aumento anómalo del tráfico de red, lentitud generalizada de los sistemas, reinicios inesperados o alertas de sistemas de detección.

Contención: Se aislarán inmediatamente los equipos infectados desconectándolos de la red corporativa. Se aplicará segmentación de red y se bloquearán los puertos utilizados por el gusano.

Mitigación: Se aplicarán parches de seguridad, se actualizarán firmas de antivirus y se reforzarán las políticas de firewall para evitar nuevas propagaciones.

Erradicación y recuperación: El gusano será eliminado de los sistemas afectados, restaurando aquellos equipos dañados desde copias de seguridad verificadas.

7.2. Playbook: Ataque de Phishing

Detección: Los ataques de phishing se detectan principalmente por el reporte de usuarios que reciben correos sospechosos o por alertas del sistema de correo electrónico.

Contención: Se bloquearán los enlaces maliciosos, se eliminarán los correos de los buzones y se deshabilitarán las cuentas que hayan podido verse comprometidas.

Mitigación: Se forzará el cambio de credenciales y se revisarán los accesos realizados con las cuentas afectadas.

Erradicación y recuperación: Se restaurará la seguridad de las cuentas y se reforzará la concienciación de los usuarios.

7.3. Playbook: Malware en Sistemas Windows

Detección: Se detecta mediante alertas antivirus, comportamiento anómalo del sistema o informes del usuario.

Contención: El sistema afectado será aislado de la red para evitar la propagación del malware.

Mitigación: Se analizará el tipo de malware, se eliminará mediante herramientas de seguridad y se verificará la integridad del sistema.

Erradicación y recuperación: Se reinstalará el sistema si es necesario y se restaurarán los datos desde copias seguras.

7.4. Playbook: Ataque de Denegación de Servicio (DDOS)

Detección: Los ataques DDOS se detectan por la indisponibilidad de servicios y picos de tráfico inusuales.

Contención: Se activarán mecanismos de filtrado y bloqueo de tráfico sospechoso y se coordinará la respuesta con proveedores.

Mitigación: Se ajustarán configuraciones de red y se redirigirá tráfico malicioso.

Erradicación y recuperación: Una vez cesado el ataque, se normalizarán los servicios y se revisarán las defensas.

7.5. Playbook: Ransomware

Detección: El ransomware se detecta por el cifrado de archivos y mensajes de rescate.

Contención: Se aislarán inmediatamente los sistemas afectados para evitar la propagación.

Mitigación: Se evaluará el alcance del cifrado y se preservarán evidencias para análisis legal.

Erradicación y recuperación: Se restaurarán los sistemas desde copias de seguridad verificadas y se reforzarán las medidas de prevención.

8. Cierre del incidente y Revisión Posterior (AAR)

Una vez que el incidente haya sido contenido, mitigado y los sistemas se encuentren recuperados, se realizará un informe de revisión posterior (After Action Review – AAR) para evaluar la gestión del incidente y generar aprendizajes que fortalezcan la organización frente a futuros incidentes.

8.1. Convocatoria y Preparación del AAR

- Se programará una reunión de AAR dentro del plazo establecido e incluirá como participantes clave:
 - El responsable de Incidente.
 - Los responsables de los servicios afectados.
 - Responsables técnicos involucrados en la respuesta.
- Se designará un responsable del AAR, encargado de recopilar información y preparar la revisión antes de la reunión, revisando procesos, notas y reportes del incidente.

8.2. Desarrollo de la Reunión de AAR

Durante la reunión se documentarán respuestas y análisis a las siguientes preguntas clave:

¿Qué sucedió?

- Crear una **línea de tiempo** de los hechos, apoyada en datos y evidencias.
- Evitar asignar culpas; centrarse en los hechos y evidencias objetivas.

¿Qué debería haber sucedido?

- Analizar desviaciones respecto a procedimientos, buenas prácticas o protocolos internos.
- Evaluar cómo el incidente podría haberse **detectado antes** o respondido con mayor eficacia.

¿Cuáles fueron las causas raíz?

- Identificar las causas principales tanto de los problemas que ocurrieron como de las fallas en la prevención o control.

¿Cómo podemos mejorar?

- Capturar acciones concretas, asignando responsables y fechas de cumplimiento.
- Considerar recomendaciones de tipo **Stop/Start/Continue**:
 - **Stop**: qué prácticas deben detenerse.
 - **Start**: qué nuevas acciones o controles se deben implementar.
 - **Continue**: qué acciones actuales son efectivas y deben mantenerse.

8.3. Comunicación y Estado del AAR

El responsable del AAR, en coordinación con el enlace interno, comunicará el estado y resultados de la revisión, durante los diferentes estados de la misma, hasta su cierre.

9.4. Incorporación de Lecciones Aprendidas

- Las lecciones aprendidas del incidente se integrarán en los procedimientos, protocolos y planes de formación del personal.
- Se actualizarán las políticas, playbooks y planes de respuesta ante incidentes según los hallazgos del AAR, fortaleciendo la capacidad de la empresa para gestionar futuros incidentes.